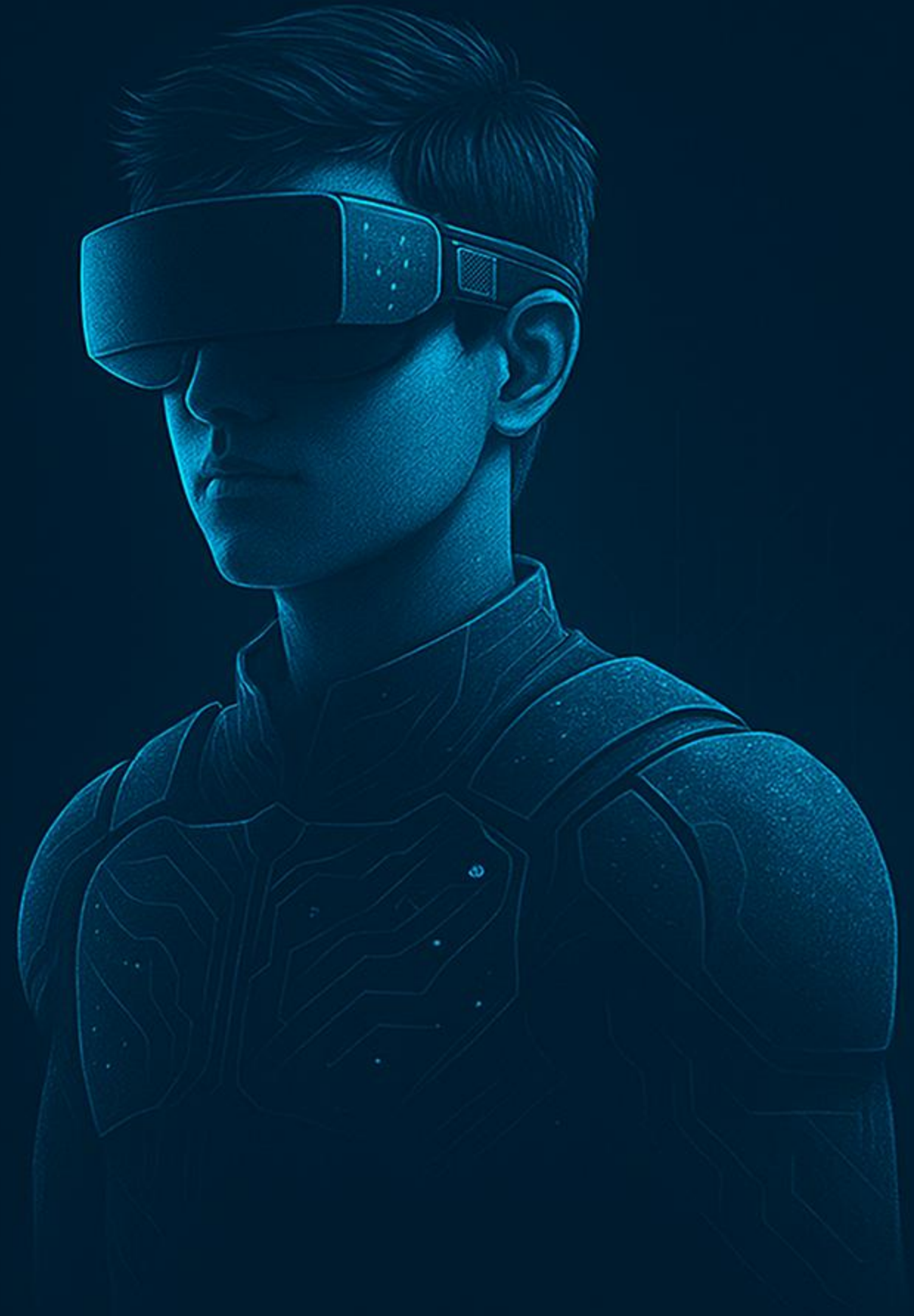


Module 5: Systems & Services Management

Module Review



What We Covered

- • Group Policy and Password Policy
- • Restricted Groups + AppLocker
- • WSUS — Update Lifecycle Management
- • Backups — Full / Incremental / Differential
- • VSS, Storage, Disaster Recovery
- • BIA, Runbooks, Tabletop Exercises
- • Service Accounts and gMSA
- • Hardening, Compliance, Documentation
- • Monitoring, WEF, PowerShell automation

Group Policy + Password Policy

- • GPO = centralized control over thousands of machines
- • Creating a GPO does not enable it — must Link to target
- • Processing order: Local → Site → Domain → OU (LSDOU)
- • Default Domain Policy — never modify, create separate GPOs
- • Four password policy levers:
 - Length (NIST 2024 recommends 12-15 chars minimum)
 - Complexity (3 of 4 character categories)
 - History (block last 10 reused passwords)
 - Maximum age (365 days, not 30 — modern best practice)
- • gpupdate /force = immediate refresh; gpresult /r = show applied

Restricted Groups + AppLocker

- • Restricted Groups — enforce membership from central AD
- • Example: Local Administrators contains only Domain Admins
- • AppLocker — application whitelisting (EXE, MSI, scripts)
- • Always start with Audit only; switch to Enforce after tuning
- • Application Identity Service must be running — otherwise silent
- • Whitelisting catches new malware; blacklisting cannot

WSUS — Update Lifecycle

- • Internal proxy for Microsoft Updates — download once, distribute
- • Four-stage lifecycle:
 - Sync from Microsoft Update
 - Approve by analyst
 - Distribute to clients via GPO
 - Report — installation status
- • Computer Groups: Pilot (5%) then Production (95%)
- • Patch Tuesday — second Tuesday of every month
- • GPO points clients to WSUS, port 8530 (HTTP) or 8531 (HTTPS)
- • Deprecated since 2024 — modern alternatives: Intune, Autopatch

Backups — Types and Strategies

- Backup types:
 - Full — complete copy, slowest but easiest to restore
 - Incremental — only changes since last backup of any kind
 - Differential — only changes since last Full backup
- 3-2-1 Rule: 3 copies, 2 different media, 1 off-site
- 3-2-1-1-0 modern: + 1 immutable (air-gapped), 0 errors verified
- RPO = how much data you can lose; RTO = how long to recover
- Backup that has not been tested is not a backup
- WannaCry 2017: paid ransom because backups were also encrypted

VSS, Storage, Disaster Recovery

- • VSS = Volume Shadow Copy Service
- • Live backups of databases and AD without service downtime
- • Previous Versions = end-user self-service file recovery
- • Backup ≠ DR — Backup is data, DR is process + people
- • DR site types (by RTO and cost):
 - Cold — infrastructure only, RTO in days
 - Warm — partial config, RTO in hours
 - Hot — full sync, RTO in minutes, expensive
- • Ransomware 60-day dwell time — backups themselves get attacked
- • A plan that has not been tested is not a plan

DR Planning — BIA, Runbook, Tabletop

- • BIA — Business Impact Analysis: how much does each outage hurt?
- • Per service:
 - Criticality (Critical / High / Medium / Low)
 - Maximum tolerable downtime
 - Data loss tolerance
 - Cost per hour of downtime
- • Runbook — explicit steps anyone can follow at 3am
- • Structure: Trigger → Diagnose → Triage → Restore → Verify
- • Tabletop Exercise — physical drill, not just paper
- • Post-Mortem after every incident — update the runbook

Service Accounts + gMSA

- • Problem: traditional service accounts have a fixed password in 30 places
- • gMSA solution:
 - Random 240-character password
 - Auto-rotates every 30 days
 - No human ever knows it
 - Only authorized hosts can retrieve it from AD
- • Setup requirements:
 - KdsRootKey active in domain
 - AD group containing authorized hosts
 - Reboot of the host after group membership change
- • Test-ADServiceAccount = True → it works
- • Suitable for: SQL, IIS, Scheduled Tasks
- • Not suitable for: interactive logon

Hardening, Compliance, Documentation

- • Service hardening: disable unused services, close ports, IIS/SQL
- • Microsoft Security Baselines — recommended settings as GPO
- • CIS Benchmarks — detailed industry standard
- • Change Management: Request → Approve → Test → Deploy → Verify
- • Compliance frameworks: ISO 27001, SOC 2, PCI-DSS, GDPR, HIPAA
- • Documentation = proof for auditors
- • Hardening without documentation = audit will fail

Monitoring + Automation

- Local Event Viewer = single-machine. WEF = scale.
- Source Computers → Collector → SIEM (Splunk / ELK)
- Subscriptions in Event Collector — who sends what
- Sysmon — process tracking, network, DLLs (SOC essential)
- PowerShell at scale:
 - DSC — Desired State Configuration
 - Remoting — Enter-PSSession, Invoke-Command
 - Role-specific modules — AD, GPO, DNS, ADCS
- Manual on 100 servers = 100 hours. Automated = 10 minutes.

Lab Pack Overview

- • Guide-01 — VirtualBox Basics (install, snapshots, networking)
- • Lab-00 — Environment Setup (AD DS install, DC promote, WS join)
- • Lab-01 — Password Policy GPO
- • Lab-02 — WSUS
- • Lab-03 — Backup + VSS
- • Lab-04 — Linux Backup (rsync, cron, SSH)
- • Lab-05 — DR Documentation (BIA + Runbook + Tabletop)
- • Lab-06 — gMSA
- • All labs include snapshots, callouts, checklists, bonus challenges

Key Takeaways

- • GPO — centralized control over thousands of machines
- • WSUS — controlled rollout, Pilot then Production
- • 3-2-1 Rule — backup not tested $\neq$ backup
- • Backup $\neq$ DR — DR is a process, not just data
- • gMSA solves service account exposure — automatic rotation
- • Documentation + Change Management — survival in disaster + audit
- • PowerShell, WEF, DSC — without automation, scale collapses

What's Next — Module 6

- Done: AD, GPO, WSUS, Backup, DR, gMSA + 6 hands-on labs
-
- Module 6 — Cybersecurity Fundamentals (50 hours)
- Major topics:
 - Threat Intelligence + MITRE ATT&CK
 - OSINT, Reconnaissance, Shodan, Nmap
 - CVEs, Exploits, Metasploit
 - Phishing + Email Security (SPF/DKIM/DMARC)
 - Password Cracking (Hashcat) + Kerberoasting
 - Wireshark, C2 Detection, DNS Tunneling
 - Static + Dynamic Malware + Volatility Memory Forensics
 - SIEM (Splunk), Sigma Rules, SOAR
- 23 dummy-proof labs ready: Lab-00 (Kali) through Lab-22 (SIEM)

CyberLabs · Module 5 Complete

Thank You

